

GCU Events Management System - Spring Boot Security Implementation

Owen Lindsey

Professor Sluiter, Shad

CST-407

Grand Canyon University

This implementation guide distills `CST-407-RS-T6-Activity-6-Implementing-REST-API-Security-JWT.docx` into a working reference for the completed codebase. It highlights the security architecture, the development workflow, and the test evidence captured in the accompanying screenshots.

Objectives

- **JWT Fundamentals:** describe token anatomy (header, payload, signature) and stateless authentication.
- **Secure Integration:** wire JWT-based security into a Spring Boot REST API.
- **Token Lifecycle:** issue, validate, and parse tokens with signed expiration claims.
- **Request Guarding:** route traffic through Spring Security filters instead of sessions.
- **Credential Safety:** hash and verify passwords via BCrypt.
- **Hands-on Testing:** exercise the API with curl, Swagger UI, or the provided sample client.

Project Overview

Spring Boot hosts two main resource collections; users and orders, secured with JWT. The authentication journey is simple: submit credentials, receive a signed token, and present that token on each protected call.

Key runtime traits:

- **API surface:** `/api/users` (registration, login, profile) and `/api/orders` (CRUD).
eyJhbGciOiJIUzI1NiJ9.eyJzdWIiOiJhbGljZSIsInJvbGVzIjpBIJPTeVfVVNFUIJdLCJpYXQiOiE3NjExNTkzOTMsImV4cCI6MTc2MTE2Mjk5M30.dF7I2fWLE0nbeyPvp1nef63QaWPQlcLaf2L_ab7xSs- **Security flow:** login → receive `Authorization: Bearer <token>` → access guarded endpoints.
- **Data storage:** H2 in-memory DB with JPA mappings for `UserAccount` and `CustomerOrder`.
- **Secret storage:** BCrypt password hashing ensures credentials are never stored in plain text.
- **Token services:** `JwtTokenProvider` encapsulates signing, validation, and claim extraction.
- **Filter chain:** `JwtAuthenticationFilter` inspects every request to populate the security context.

Key Components

Area	Files / Classes	Purpose
Build + Dependencies	<code>pom.xml</code>	Declares Spring Boot starters, JWT libs, H2, and validation.
Security Infrastructure	<code>SecurityConfig</code> , <code>JwtAuthenticationFilter</code> , <code>JwtTokenProvider</code>	Configures stateless security, validates tokens, and loads principals.
Authentication Services	<code>AuthService</code> , <code>CustomUserDetailsService</code> , <code>UserService</code>	Authenticate credentials, fetch user details, and manage registration.
API Layer	<code>UsersController</code> , <code>OrdersController</code> , <code>GlobalExceptionHandler</code>	Expose REST endpoints and standardize error responses.
Data Tier	<code>UserAccount</code> , <code>CustomerOrder</code> , repositories, <code>DataInitializer</code>	Model domain entities, persist data, and seed demo records.

JWT Configuration

JWT behavior is tuned via `src/main/resources/application.properties`:

```
jwt.secret=change-me-in-production
jwt.expiration=3600000 # milliseconds (1 hour)
```

Running the Project

1. **Prepare tooling.** JDK 17+ and Maven must be available on your PATH.
2. **Start the service.**

```
cd JWT/jwt-secured-api
mvn spring-boot:run
```

3. **Authenticate and test.** Issue requests with curl, Swagger UI, or Postman to register/login and then supply the bearer token on protected routes.

Need a UI? Launch `http://localhost:8080/swagger-ui/index.html` and interact with every endpoint in the browser.

Testing the API Manually

```
# Register a user
curl -X POST http://localhost:8080/api/users/register \
  -H 'Content-Type: application/json' \
  -d '{ "username": "dev", "password": "Password!23", "fullName": "Dev Team" }'

# Authenticate and capture token
TOKEN=$(curl -s -X POST http://localhost:8080/api/users/login \
  -H 'Content-Type: application/json' \
  -d '{ "username": "dev", "password": "Password!23" }' | jq -r '.token')

# Call a protected endpoint
curl http://localhost:8080/api/orders \
  -H "Authorization: Bearer $TOKEN"
```

Screenshots & Scenario Walkthrough

Every image in Screenshots/ corresponds to a checkpoint in the security flow:

- **Bootstrapping:**

```
Neo-tree
/run/media/omniv/T7/GCU_SWE_2023-2025
  AIT-104-Data-mining-machine-learnin
  CST-150-C#1
  CST-180-Python
  CST-201-algorithms-data-structures
  CST-239-Java2
  CST-250-C#2
  CST-321-Operating-system-fundamenta
  CST-326-Written-Verbal-Communicatio
  CST-339-Java3
  CST-345-Database-Design
  CST-350-C#3
  CST-391-Web_dev
  CST-407-Application-Security-Founda
    Assignments
    Class Notes
    Homework_references
    Notes
    Templates
    archives
    coding
      CST-407-RS-T5-Milestone-Event
      JWT
      Swagger UI_files
      jwt-secured-api
        src
          main
            java
              edu
                gcu
                  cst407
                    jwt
                      config
                      controller
                      dto
                      model
                      repository
                      security
                      service
                    JmtSecuredApi
          resources
          test
        target
          classes
          generated-sources
          generated-test-sources
          maven-status
          test-classes
        pom.xml
      (2 hidden items)
    CST-407-RS-T6-Activity-6-Impl
    README.md
    Swagger UI.html
  Spring Security
  blockchaindemo
  encryption
  hashingapp
  loginapp
  (3 hidden items)
  imgs
  README.md
  Syllabus_CST-407-WF900A-20250902
  generate_development_pdf.bat
  $ generate_development_pdf.sh
  {}workspace.json
  (2 hidden items)
  SummerPractice
  LICENSE
  README.md
  {}REPO_ORGANIZATION_PLAN.md
  {}orders-response.json
  {}swagger-spec.json
  (4 hidden items)

JwtSecuredApiAppl... x | bash x
:: Spring Boot :: (v3.2.5)

2025-10-22T10:39:23.786-07:00 INFO 11452 --- [jwt-secured-api] [main] e.g.cst407.jwt.JwtSecuredApiApplication : Starting J
wtSecuredApiApplication using Java 25.0.1 with PID 11452 (/run/media/omniv/T7/GCU_SWE_2023-2025/CST-407-Application-Security-Founda
s/coding/JWT/jwt-secured-api/target/classes started by omniv in /run/media/omniv/T7/GCU_SWE_2023-2025/CST-407-Application-Security-Foun
dations/coding/JWT/jwt-secured-api)
2025-10-22T10:39:23.787-07:00 INFO 11452 --- [jwt-secured-api] [main] e.g.cst407.jwt.JwtSecuredApiApplication : No active
profile set, falling back to 1 default profile: "default"
2025-10-22T10:39:24.083-07:00 INFO 11452 --- [jwt-secured-api] [main] .s.d.r.c.RepositoryConfigurationDelegate : Bootstrapp
ing Spring Data JPA repositories in DEFAULT mode.
2025-10-22T10:39:24.105-07:00 INFO 11452 --- [jwt-secured-api] [main] .s.d.r.c.RepositoryConfigurationDelegate : Finished S
pring Data repository scanning in 18 ms. Found 2 JPA repository interfaces.
WARNING: A restricted method in java.lang.System has been called
WARNING: java.lang.System::load has been called by org.apache.tomcat.jni.Library in an unnamed module (file:/home/omniv/.m2/repository/
org/apache/tomcat/embed/tomcat-embed-core/10.1.20/tomcat-embed-core-10.1.20.jar)
WARNING: Use --enable-native-access=ALL-UNNAMED to avoid a warning for callers in this module
WARNING: Restricted methods will be blocked in a future release unless native access is enabled

2025-10-22T10:39:24.318-07:00 INFO 11452 --- [jwt-secured-api] [main] o.s.b.w.embedded.tomcat.TomcatWebServer : Tomcat ini
tialized with port 8080 (http)
2025-10-22T10:39:24.323-07:00 INFO 11452 --- [jwt-secured-api] [main] o.apache.catalina.core.StandardService : Starting s
ervice [Tomcat]
2025-10-22T10:39:24.323-07:00 INFO 11452 --- [jwt-secured-api] [main] o.apache.catalina.core.StandardEngine : Starting S
ervlet engine: [Apache Tomcat/10.1.20]
2025-10-22T10:39:24.341-07:00 INFO 11452 --- [jwt-secured-api] [main] o.a.c.c.C.[Tomcat].[localhost].[/] : Initializi
ng Spring embedded WebApplicationContext
2025-10-22T10:39:24.341-07:00 INFO 11452 --- [jwt-secured-api] [main] w.s.c.ServletWebServerApplicationContext : Root WebAp
plicationContext: initialization completed in 535 ms
2025-10-22T10:39:24.357-07:00 INFO 11452 --- [jwt-secured-api] [main] com.zaxxer.hikari.HikariDataSource : HikariPool
-1 - Starting...
2025-10-22T10:39:24.436-07:00 INFO 11452 --- [jwt-secured-api] [main] com.zaxxer.hikari.pool.HikariPool : HikariPool
-1 - Added connection conn0: url=jdbc:h2:mem:jwt_db user=SA
2025-10-22T10:39:24.436-07:00 INFO 11452 --- [jwt-secured-api] [main] com.zaxxer.hikari.HikariDataSource : HikariPool
-1 - Start completed.
2025-10-22T10:39:24.442-07:00 INFO 11452 --- [jwt-secured-api] [main] o.s.b.a.h2.H2ConsoleAutoConfiguration : H2 console
available at '/h2-console'. Database available at 'jdbc:h2:mem:jwt_db'
2025-10-22T10:39:24.489-07:00 INFO 11452 --- [jwt-secured-api] [main] o.hibernate.jpa.internal.util.LogHelper : HHH000204:
Processing PersistenceUnitInfo [name: default]
2025-10-22T10:39:24.510-07:00 INFO 11452 --- [jwt-secured-api] [main] org.hibernate.Version : HHH000412:
Hibernate ORM core version 6.4.4.Final
2025-10-22T10:39:24.522-07:00 INFO 11452 --- [jwt-secured-api] [main] o.h.c.internal.RegionFactoryInitiator : HHH000026:
Second-level cache disabled
2025-10-22T10:39:24.601-07:00 INFO 11452 --- [jwt-secured-api] [main] o.s.o.j.p.SpringPersistenceUnitInfo : No LoadTim
eWeaver setup: ignoring JPA class transformer
2025-10-22T10:39:24.929-07:00 INFO 11452 --- [jwt-secured-api] [main] o.h.e.t.j.p.i.JtaPlatformInitiator : HHH000489:
No JTA platform available (set 'hibernate.transaction.jta.platform' to enable JTA platform integration)
Hibernate: create table orders (id bigint generated by default as identity, description varchar(200) not null, order_date date not null
, total numeric(38,2) not null, user_id bigint not null, primary key (id))
Hibernate: create table users (id bigint generated by default as identity, created_at timestamp(6) with time zone not null, full_name v
archar(120) not null, password varchar(255) not null, role varchar(40) not null, username varchar(80) not null, primary key (id))
Hibernate: alter table if exists users drop constraint if exists UK_r43af9ap4edm43mmtq01oddj6
Hibernate: alter table if exists users add constraint UK_r43af9ap4edm43mmtq01oddj6 unique (username)
Hibernate: alter table if exists orders add constraint FK32ql8ubntj5uh44ph9659tjih foreign key (user_id) references users
2025-10-22T10:39:24.955-07:00 INFO 11452 --- [jwt-secured-api] [main] j.LocalContainerEntityManagerFactoryBean : Initialize
d JPA EntityManagerFactory for persistence unit 'default'
2025-10-22T10:39:25.166-07:00 WARN 11452 --- [jwt-secured-api] [main] JpaBaseConfiguration$JpaWebConfiguration : spring.jpa
.open-in-view is enabled by default. Therefore, database queries may be performed during view rendering. Explicitly configure spring.jp
a.open-in-view to disable this warning
2025-10-22T10:39:25.285-07:00 INFO 11452 --- [jwt-secured-api] [main] o.s.s.web.DefaultSecurityFilterChain : Will secur
e any request with [org.springframework.security.web.session.DisableEncodeUrlFilter@4fccdd1d, org.springframework.security.web.context.
request.async.WebAsyncManagerIntegrationFilter@22c0c0bc, org.springframework.security.web.context.SecurityContextHolderFilter@1be3e952,
org.springframework.security.web.header.HeaderWriterFilter@1a3272e0, org.springframework.web.filter.CorsFilter@36a25457, org.springfra
mework.security.web.authentication.Logout.LogoutFilter@580ac0b, edu.gcu.cst407.jwt.security.JwtAuthenticationFilter@205b73d8, org.spr
ingframework.security.web.savedrequest.RequestCacheAwareFilter@7004cd44, org.springframework.security.web.servletapi.SecurityContextHold
erAwareRequestFilter@495e1ad1, org.springframework.security.web.authentication.AnonymousAuthenticationFilter@61d4155b, org.springframew
ork.security.web.session.SessionManagementFilter@3514df8d, org.springframework.security.web.access.ExceptionTranslationFilter@689f9cf08,
org.springframework.security.web.access.intercept.AuthorizationFilter@29088d3d]
2025-10-22T10:39:25.409-07:00 INFO 11452 --- [jwt-secured-api] [main] o.s.b.w.embedded.tomcat.TomcatWebServer : Tomcat sta
rted on port 8080 (http) with context path ''
2025-10-22T10:39:25.413-07:00 INFO 11452 --- [jwt-secured-api] [main] e.g.cst407.jwt.JwtSecuredApiApplication : Started Jw
tSecuredApiApplication in 1.767 seconds (process running for 1.881)
Hibernate: select count(*) from users ua1_0
Hibernate: insert into users (created_at,full_name,password,role,username,id) values (?,?,,?,?,default)
Hibernate: insert into users (created_at,password,role,username,id) values (?,?,,?,?,default)
Hibernate: insert into orders (description,order_date,total,user_id,id) values (?,?,,?,?,default)
Hibernate: insert into orders (description,order_date,total,user_id,id) values (?,?,,?,?,default)
Hibernate: insert into orders (description,order_date,total,user_id,id) values (?,?,,?,?,default)
Hibernate: insert into orders (description,order_date,total,user_id,id) values (?,?,,?,?,default)
```

confirms the service, H2 database, and filter chain all start successfully.

Onboarding: users-controller

POST

/api/users/register

Parameters

Cancel

Reset

No parameters

Request body required

application/json

{

"username": "devuser",

"password": "Password!12",

"fullName": "dev_user"

}

Execute

Clear

Responses

Curl

```
curl -X 'POST' \
  'http://localhost:8080/api/users/register' \
  -H 'accept: */*' \
  -H 'Content-Type: application/json' \
  -d '{
    "username": "devuser",
    "password": "Password!12",
    "fullName": "dev_user"
  }'
```

Request URL

http://localhost:8080/api/users/register

Server response

Code

Details

201

Undocumented

Response body

```
{
  "id": 3,
  "username": "devuser",
  "fullName": "dev_user",
  "role": "ROLE_USER",
  "createdAt": "2025-10-22T17:48:47.505585386Z"
}
```

Download

demonstrates server-side validation and BCrypt hashing when creating users.

- **Authentication:**

POST

/api/users/login

Parameters

Cancel

Reset

No parameters

Request body

required

application/json

```
{
  "username": "devuser",
  "password": "Password!12"
}
```

Execute

Clear

Responses

Curl

```
curl -X 'POST' \
  'http://localhost:8080/api/users/login' \
  -H 'accept: */*' \
  -H 'Content-Type: application/json' \
  -d '{
    "username": "devuser",
    "password": "Password!12"
  }'
```

Request URL

http://localhost:8080/api/users/login

Server response

Code

Details

200

Response body

```
{
  "token": "eyJhbGciOiJIUzI1NiJ9.eyJzdWIiOiJkZXZ1c2VyIiwicm9sZXMiOiJ1b3RlbnR1cyJ9",
  "expiresAt": "2025-10-22T18:50:08.558740669Z",
  "tokenType": "Bearer"
}
```

Download

Response headers

```
cache-control: no-cache,no-store,max-age=0,must-revalidate
connection: keep-alive
content-type: application/json
date: Wed, 22 Oct 2025 17:50:08 GMT
expires: 0
keep-alive: timeout=60
pragma: no-cache
transfer-encoding: chunked
vary: Origin,Access-Control-Request-Method,Access-Control-Request-Headers
x-content-type-options: nosniff
x-frame-options: SAMEORIGIN
x-xss-protection: 0
```

Responses

Code

Description

Links

200

OK

No links

Media type

/

Controls Accept header.

Example Value | Schema

```
{
  "token": "string",
  "expiresAt": "2025-10-22T17:50:08.573Z",
  "tokenType": "string"
}
```

records the JWT payload returned to the caller.

• Identity Verification:

GET

/api/users/me



Parameters

No parameters

Execute

Clear

Responses

Curl

```
curl -X 'GET' \
'http://localhost:8080/api/users/me' \
-H 'accept: */*' \
-H 'Authorization: Bearer eyJhbGciOiJIUzI1NiJ9.eyJzdWIiOiJkZXZ1c2VyIiwicm9sZXMiOiJ1Uk9MRV9VU0VSIl0sImhhdCI6MTc2MTE1NTQwOCwiZXhwIjo
```

Request URL

http://localhost:8080/api/users/me

Server response

Code	Details
200	Response body <pre>{ "id": 3, "username": "devuser", "fullName": "dev_user", "role": "ROLE_USER", "createdAt": "2025-10-22T17:48:47.505585Z" }</pre> Download Response headers <pre>cache-control: no-cache,no-store,max-age=0,must-revalidate connection: keep-alive content-type: application/json date: Wed,22 Oct 2025 17:51:03 GMT expires: 0 keep-alive: timeout=60 pragma: no-cache transfer-encoding: chunked vary: Origin,Access-Control-Request-Method,Access-Control-Request-Headers x-content-type-options: nosniff x-frame-options: SAMEORIGIN x-xss-protection: 0</pre>

Responses

Code	Description	Links
200	OK Media type */* Controls Accept header. Example Value Schema <pre>{ "id": 0, "username": "string", "fullName": "string", "role": "string", "createdAt": "2025-10-22T17:51:03.602Z" }</pre>	No links

shows that `/api/users/me` is unreachable without a bearer token.

• Data Access:

GET

/api/orders/{id}

Parameters

Cancel

Name	Description
id ★ required	
integer(\$int64) (path)	1

Execute

Clear

Responses

Curl

```
curl -X 'GET' \
'http://localhost:8080/api/orders/1' \
-H 'accept: */*' \
-H 'Authorization: Bearer eyJhbGciOiJIUzI1NiJ9.eyJzdWIiOiJkZXZ1c2VyIiwicm9sZXMiOiJ0b3RlciIsImh0dCI6MTc2MTE1NTQwOCwiZXhwIjoz
```

Request URL

http://localhost:8080/api/orders/1

Server response

Code	Details
500 <i>Undocumented</i>	Error: response status is 500 Response body <pre>{ "timestamp": "2025-10-22T17:59:15.714+00:00", "status": 500, "error": "Internal Server Error", "path": "/api/orders/1" }</pre> Download Response headers <pre>cache-control: no-cache,no-store,max-age=0,must-revalidate connection: close content-type: application/json date: Wed,22 Oct 2025 17:59:15 GMT expires: 0 pragma: no-cache transfer-encoding: chunked vary: Origin,Access-Control-Request-Method,Access-Control-Request-Headers x-content-type-options: nosniff x-frame-options: SAMEORIGIN x-xss-protection: 0</pre>

Responses

Code	Description	Links
200	OK Media type */* Controls Accept header. Example Value Schema	No links

Gets the id 1 itmeprove orders are filtered by the authenticated principal.

• State Changes:

DELETE

/api/orders/{id}



Parameters

Cancel

Name	Description
id ★ required	
integer(\$int64)	1
(path)	

Execute

Clear

Responses

Curl

```
curl -X 'DELETE' \
'http://localhost:8080/api/orders/1' \
-H 'accept: */*' \
-H 'Authorization: Bearer eyJhbGciOiJIUzI1NiJ9.eyJzdWIiOiJhbGJZSIsInJvbmVzIjpbILJPTEVfVVNFUiJdLCJpYXQiOiJlE3NjExNTkzOTMsImV4cCI6MTc2
```

Request URL

http://localhost:8080/api/orders/1

Server response

Code	Details
204	

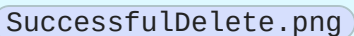
Undocumented

Response headers

```
cache-control: no-cache,no-store,max-age=0,must-revalidate
connection: keep-alive
date: Wed,22 Oct 2025 18:56:52 GMT
expires: 0
keep-alive: timeout=60
pragma: no-cache
vary: Origin,Access-Control-Request-Method,Access-Control-Request-Headers
x-content-type-options: nosniff
x-frame-options: SAMEORIGIN
x-xss-protection: 0
```

Responses

Code	Description	Links
200	OK	No links

and  capture protected POST/DELETE flows that succeed only with valid credentials.

• Add an Order:

POST

/api/orders

Parameters

No parameters

Request body required

application/json

```
{
  "description": "Adding this new shiny thing",
  "total": 1,
  "orderDate": "2025-10-22"
}
```

Execute

Clear

Responses

Curl

```
curl -X 'POST' \
  'http://localhost:8080/api/orders' \
  -H 'accept: */*' \
  -H 'Authorization: Bearer eyJhbGciOiJIUzI1NiJ9.eyJzdWIiOiJhbGljZSIsInJvbGZzIjpbIlJPTEVfVVNFUiJdLCJpYXQiOiJlE3NjExNTkzOTMsImV4cCI6MTc3
  -H 'Content-Type: application/json' \
  -d '{
    "description": "Adding this new shiny thing",
    "total": 1,
    "orderDate": "2025-10-22"
  }'
```

Request URL

http://localhost:8080/api/orders

Server response

Code

Details

201

Undocumented

Response body

```
{
  "id": 5,
  "description": "Adding this new shiny thing",
  "total": 1,
  "orderDate": "2025-10-22",
  "createdBy": "Alice Anderson"
}
```

Download

Response headers

```
cache-control: no-cache,no-store,max-age=0,must-revalidate
connection: keep-alive
content-type: application/json
date: Wed,22 Oct 2025 19:00:50 GMT
expires: 0
keep-alive: timeout=60
pragma: no-cache
transfer-encoding: chunked
vary: Origin,Access-Control-Request-Method,Access-Control-Request-Headers
x-content-type-options: nosniff
x-frame-options: SAMEORIGIN
x-xss-protection: 0
```

Responses

• *Order Look up:

Cancel

Clear

```
{
  "id": 0,
  "description": "string",
  "total": 0,
  "orderDate": "2025-10-22",
  "createdBy": "string"
}
```